Vulnérabilité Web dans les Applications Client Lourdes

Même si une application client lourde utilise une architecture 3 niveau sa communication avec le serveur d'application est une surface d'attaque critique, ces application peuvent souffrir de vulnérabilités comme l'injection SQL ou le path transversal...

L'étape clé est l'analyse du client par décompilations pour inspecter la logique métier, et les configurations codées en dur Les applications sont souvent signés pour empêcher toute modifications, si on modifie un fichier on doit également modifier le control d'intégrité par exemple en modifiant les fichiers de signatures et hashages du repertoir META-INF avant de recompiler le fichier

Utiliser l'analyse réseau pour voir comment notre application communique et bien comprendre la logique métier de l'application

ColdFusion Découverte et Enumération :

ColdFusion est une plateforme de développement d'applications web basées sur java. Elle utilise son propre langage le CFML (Cold Fusion Markup Language) qui ressemble à du HTML avec des balises spécifiques, pour interagir facilement avec des bases de données et simplifier le développement



Coldfusion utilise des ports caractéristiques pouvant être détectés lors d'un scan réseau, parmi lesquels, 80 (HTTP), 443 (HTTPS), 8500 (Communication Serveur SSL), 5500 (Surveillance serveur). Coldfusion utilise également des extentions atypiques (.cfm ou .cfc) pouvant être identifiés. Le serveur peux également envoyé des entêtes permetant de l'identifier comme X-Powered-By: ColdFusion, Il y a également des chemins d'installations par défault comme : /CFIDE/administrator/index.cfm

Par le passé coldfusion à également souffert de plusieurs vulnérabilités critiques comme des exécutions de code à distance, traversée de repertoires ou encore arbitrary files upload. La découverte d'un panneau d'administration peux dévoiler la version de l'instance coldfusion

Attaquer Cold Fusion :

Après c'est comme dans toute les technologies il faux étudier le system et se documenter, notons simplement que searsploit possède des exploits valides et fonctionnels pour toutes les grosses failles ayant touchés coldfusion

Notons que pour les versions <= 8 c'est RCE directement sans authentification.
Mais voila pour coldfusion la quasi totalité des failles sont simples à comprendre et à exploiter

Enumération par tilde d'IIS

A l'époque de MS-DOS et de windows 3.1 le system de fichier ne pouvait pas gérer de noms complexes et imposait une stricte limite, 8 caractère pour le nom suivi d'un point et de 3 caractères pour l'extention.
L'arrivée des noms longs et l'evolution de NTFS à permis aux utilisateurs de nommer leurs fichiers de manière moderne mais pour eviter que les logiciels anciens ne plantent en lisant ces vieux noms de fichiers, Windows gère automatiquement en arrière plan un alias court transparent. IIS à l'inverse de ce mécanisme



- Pour générer ces noms courts windows prend les 6 premiers caractères valides de ce long nom ignorant les espaces, il ajoute un tilde (~) suivi d'un chiffre généralement 1 et il prend les 3 premiers caractère de l'extention

Exemple : administrator_panel.aspx => ADMINI~1.ASP